

STARTER TEMPLATE · ADAPT BEFORE ADOPTION

AI Use Policy Starter

An adopt-and-adapt acceptable-use policy for generative AI, with verbatim clause language, a worked data-classification matrix, and the controls examiners expect.

WHO IT IS FOR

Compliance, risk, and senior management

FILL TIME

14 min

WHAT'S INSIDE

- 01 Purpose & scope
- 02 Governance & accountability
- 03 Approved tools & third-party oversight
- 04 Data classification & permitted inputs
- 05 Permitted & prohibited uses
- 06 Human review & model risk (SR 11-7)
- 07 Documentation & recordkeeping
- 08 Incident response & exceptions
- 09 Training & policy review cycle

SECTION 01

Purpose & scope

This section states why the policy exists and exactly what it covers, so staff and examiners can tell in one read whether a given activity is in bounds. The right default is broad scope (any generative tool, any channel) with risk-tiered controls layered on top — not a narrow tool-by-tool list that goes stale.

- ^a Recommended: define "Generative AI" by behavior, not brand. Adopt verbatim: "This policy applies to any system that accepts natural-language or data input and produces generated text, images, audio, video, or code, whether accessed as a standalone service, embedded in a vendor product, built into [Institution]'s core or ancillary systems, or self-hosted."
- ^a Why: a brand list (ChatGPT, Claude, Gemini, Copilot) is obsolete the day a vendor ships an AI feature inside software you already use; behavior-based scope captures embedded AI automatically.
- ^a Recommended: state the standards this policy implements so examiners see the through-line. Adopt verbatim: "This policy operationalizes [Institution]'s obligations under the GLBA information-security program, applies model-risk principles consistent with SR 11-7 where AI informs decisions, and aligns governance to the NIST AI Risk Management Framework functions of Govern, Map, Measure, and Manage."
- ^a Why: GLBA's Safeguards Rule (16 CFR 314.4) requires a written program with administrative, technical, and physical safeguards scaled to your size and the sensitivity of customer information — AI use is squarely within that program, not separate from it.
- ^a Recommended: scope to everyone, not just employees. Adopt verbatim: "This policy binds all employees, officers, directors, temporary staff, interns, and contractors who use AI in connection with [Institution] business or who handle [Institution] data with AI tools."
- ^a What good looks like: a one-paragraph scope a teller and an examiner read the same way. Common mistake examiners flag: a policy that only governs a single named chatbot while AI quietly enters through a core/loan-origination/marketing vendor with no oversight.

SECTION 02

Governance & accountability

A policy with no named owner is a finding waiting to happen. The NIST AI RMF puts Govern first for a reason, and the GLBA Safeguards Rule expressly requires you to designate a qualified individual to oversee the information-security program. Assign one accountable owner, define an approval gate, and report to the board.

- ^a Recommended: name a single accountable owner. Adopt verbatim: "The [Chief Risk Officer / Information Security Officer] is the AI Program Owner, accountable to the Board (or a designated committee) for this policy, the inventory of AI use cases, and exceptions."
- ^a Why: 16 CFR 314.4(a) requires designating a "Qualified Individual" responsible for the information-security program; naming an AI Program Owner who maps to that role avoids a gap between your security program and your AI activity.
- ^a Recommended: route approvals through one cross-functional gate. Adopt verbatim: "No new AI use case involving [Institution] data or affecting customers may go live without written approval from the AI Program Owner, with sign-off from Compliance and Information Security; high-risk use cases (see Risk tiering) also require [Committee] approval."
- ^a Recommended: report up at least annually. Adopt verbatim: "The AI Program Owner reports to the Board or its designated committee at least annually on the AI use-case inventory, material incidents, exceptions granted, and the results of the policy review."
- ^a Why: the 2023 Interagency Third-Party guidance and GLBA both treat board-level oversight of risk as expected; AI does not get a carve-out from the governance you already run.
- ^a What good looks like: an org chart line from teller to AI Program Owner to board. Common mistake examiners flag: "shadow AI" — staff using consumer tools with no inventory, no owner, and no record the board knows it is happening.

SECTION 03

Approved tools & third-party oversight

Treat every AI tool as a third-party relationship and run it through the lifecycle the 2023 Interagency Guidance describes: planning, due diligence, contracting, ongoing monitoring, and termination. The default posture is allow-list, not block-list — only vetted tools, accessed through institution-controlled accounts.

- ^a Recommended: allow-list only. Adopt verbatim: "Only AI tools on the Approved AI Tools List may be used for [Institution] business. The list is maintained by the AI Program Owner and reviewed at least quarterly. Use of any non-listed AI tool for institution work or data is prohibited."
- ^a Recommended: ban personal accounts for institution data. Adopt verbatim: "Staff may not enter [Institution] or customer information into AI tools through personal accounts, free consumer tiers, or browser extensions; only institution-provisioned accounts on approved tools may be used."
- ^a Why: free consumer tiers frequently reserve the right to train on submitted content; the 2023 Interagency Guidance and GLBA both require that contracts with service providers address confidentiality and data use for nonpublic information.
- ^a Recommended: gate listing on real due diligence. Adopt verbatim: "Before a tool is listed, Information Security and Compliance confirm a written agreement that addresses data ownership, prohibition on training the vendor's base model on [Institution] data without consent, retention and deletion, subcontractor (fourth-party) use, breach notification, and audit/SOC 2 rights."
- ^a Why: the Interagency Guidance specifically calls out assessing subcontractors and the vendor's own information-security and incident-response capabilities — "fourth-party" risk is in scope, not optional.
- ^a Worked example (Approved AI Tools List row): Tool = [Vendor] Enterprise; Access = SSO, institution-provisioned only; Permitted data classes = Public, Internal; Prohibited = Confidential, NPI/Regulated; Training opt-out = Confirmed in writing [date]; Retention = zero-retention tier enabled; Owner = [name]; Next review = [date].
- ^a What good looks like: every listed tool maps to a signed agreement and a monitoring date. Common mistake examiners flag: an "approved" tool with no contract review, no training opt-out confirmation, and no record of who owns ongoing monitoring.

SECTION 04

Data classification & permitted inputs

This is the section that prevents the headline incident. Tie AI inputs to your existing GLBA-driven data classification scheme and state, per class, where data may and may not go. The safe default: nonpublic personal information (NPI) and regulated data never enter a public or shared-tenant AI tool.

- ^a Recommended: anchor on classes you already use. Adopt verbatim: "Inputs to AI tools follow [Institution]'s data classification standard. Each class has a defined permitted destination; when in doubt, treat data as the higher-sensitivity class and ask the AI Program Owner."
- ^a Worked example — filled data-classification matrix (adapt to your standard):
- ^a Public (rate sheets, published marketing copy, public website FAQs, press releases): Allowed in any approved tool.
- ^a Internal (draft procedures, internal memos, non-customer training material, de-identified examples): Allowed in approved tools only; not in personal/consumer accounts.
- ^a Confidential — NPI (customer names with account or balance data, SSN/TIN, card/account numbers, application data, loan files, transaction history): Prohibited in any public or shared-tenant AI tool; permitted only in an approved private/zero-retention deployment with a contract that covers NPI, and only for an approved use case.
- ^a Regulated / examination-sensitive (SAR/CTR content and SAR existence, BSA/AML investigation detail, fair-lending analysis, model validation work, examination correspondence and work product, attorney-client privileged material): Prohibited in all AI tools by default; any exception requires written AI Program Owner and Compliance approval and a private deployment.
- ^a Why: GLBA's Safeguards Rule requires protecting the security and confidentiality of customer information; SAR confidentiality is independently mandated (31 U.S.C. 5318(g) / 12 CFR Part 21 et al.), so SAR detail must never enter a general-purpose tool.
- ^a Recommended: require de-identification before prompting. Adopt verbatim: "Where AI assistance is useful but the source contains NPI, staff must remove or tokenize all customer identifiers before prompting; reattaching identifiers happens only outside the AI tool."
- ^a What good looks like: a one-page matrix posted where staff prompt. Common mistake examiners flag: a policy that says "don't share confidential data" without defining the classes — staff cannot follow a rule they cannot apply to the document in front of them.

SECTION 05

Permitted & prohibited uses

Name the green-light uses so staff feel safe being productive, and name the bright-line prohibitions so no one has to guess. The default: AI may draft and summarize, but it may not make or rubber-stamp a decision that affects a customer's money, credit, or legal standing.

- ^a Recommended (permitted, illustrative): drafting internal documents and non-customer communications, summarizing internal material, brainstorming, reformatting, generating code in approved environments, and first-draft training content — all subject to human review.
- ^a Recommended (prohibited bright lines). Adopt verbatim: "AI tools may not be used to make a final credit, account-closure, fraud-disposition, BSA/AML, HR, or other adverse decision affecting a customer or employee; AI may inform a recommendation only where a qualified person makes and can independently justify the decision."
- ^a Why: under ECOA and Regulation B, a creditor must give specific, accurate principal reasons for adverse action, and CFPB Circular 2023-03 makes clear a creditor "cannot justify noncompliance based on the mere fact" that its model is "too complicated, opaque, or novel" — a black-box AdverseAction is not defensible.
- ^a Recommended: prohibit creating false or misleading content. Adopt verbatim: "AI may not be used to generate content that misrepresents [Institution] products or terms, fabricate compliance documentation, or produce material that would mislead a customer (UDAAP), an auditor, or an examiner."
- ^a Recommended: require disclosure where a customer would reasonably expect a human. Adopt verbatim: "Customer-facing AI interactions (e.g., chat) must not impersonate a human and must offer a path to a person."
- ^a What good looks like: a short green/red list staff can recite. Common mistake examiners flag: using AI in underwriting or BSA/AML decisioning without being able to produce specific, accurate reasons — a direct Reg B / fair-lending exposure.

SECTION 06

Human review & model risk (SR 11-7)

AI output is draft work product until a qualified human stands behind it. Where AI informs decisions, apply model-risk discipline proportionate to the stakes: SR 11-7's core ideas — effective challenge, validation, and ongoing monitoring — scale down to a community institution.

- ^a Why: SR 11-7 treats a "model" as any quantitative method that produces output used in decision-making; when AI informs a customer decision, model-risk expectations (validation, monitoring, documentation, effective challenge) apply at a scale proportionate to your institution.
 - ^a Note: model-risk guidance continues to evolve and agencies have signaled further AI-specific guidance is coming — apply SR 11-7 principles proportionately and revisit this section when new guidance is issued, rather than assuming AI is out of scope.
 - ^a What good looks like: a one-page validation memo for each decisioning use case. Common mistake examiners flag: "the AI checked it" offered as the control, with no human attestation and no record of testing for accuracy or bias.
1. Classify the use case by impact: low (internal drafting), medium (customer-facing content), high (informs a decision about credit, accounts, fraud, or BSA/AML). Controls scale with the tier.
 2. Require named human review before reliance. Adopt verbatim: "Every AI output used in customer-facing, regulated, or decision-supporting work is reviewed by a qualified person who is identified by name and role and who verifies factual accuracy, calculations, regulatory references, and data handling before the output is used, sent, filed, or relied upon."
 3. For high-tier (decisioning) uses, apply effective challenge: document the tool's purpose, inputs, known limitations, and how a reviewer can override it — consistent with SR 11-7's expectation that models be validated and independently challenged.
 4. Test for the failure modes that matter for generative AI: fabrication ("hallucination"), bias/disparate impact in any customer-affecting use, and prompt-injection or data-leakage risk; record the test and who performed it.
 5. Monitor on a cadence: re-review high-tier uses at least annually and on any material tool/model change, vendor update, regulatory change, or incident.

SECTION 07

Documentation & recordkeeping

If it is not documented, an examiner will treat it as if it did not happen. Keep a lightweight but consistent record for any AI-assisted work that reaches a customer, a regulated process, or a decision — enough to reconstruct what happened and who is accountable.

- ^a Recommended minimum record. Adopt verbatim: "For AI-assisted work producing a customer-facing or examiner-relevant artifact, [Institution] retains: the approved tool and version used, the prompt or instruction, the data class of the input, the output relied upon, and the human reviewer and date of review."
- ^a Recommended: keep the AI use-case inventory current. Adopt verbatim: "The AI Program Owner maintains a written inventory of all AI use cases, including purpose, owner, data classes, risk tier, approval date, and next review date," consistent with NIST AI RMF Map/Govern practices.
- ^a Recommended: align retention to your existing schedule. Adopt verbatim: "AI-related records are retained per [Institution]'s records-retention schedule and the retention applicable to the underlying business record (e.g., loan-file retention applies to AI-assisted loan documentation)."
- ^a Why: GLBA's Safeguards Rule expects periodic written risk assessment and documentation of safeguards; a maintained inventory plus per-artifact records is how you evidence that AI sits inside that program.
- ^a What good looks like: an examiner can pull any AI-assisted loan or marketing piece and see tool, prompt, data class, and reviewer. Common mistake examiners flag: an inventory built once for the exam and never updated, or no inventory at all.

SECTION 08

Incident response & exceptions

AI incidents — inadvertent NPI disclosure, prompt injection, a fabricated output that reached a customer, or unapproved tool use — ride on your existing incident-response plan, with AI-specific triggers added. Exceptions are allowed but must be deliberate, time-bound, and logged.

- ^a Recommended: fold AI into the existing plan, do not build a parallel one. Adopt verbatim: "Suspected AI policy violations, prompt-injection attempts, model misuse, or disclosure of confidential or regulated data into an AI tool are handled under [Institution]'s incident-response plan, with notice to the AI Program Owner, Compliance, and Information Security."
- ^a Recommended: set a fast internal notification clock and preserve evidence. Adopt verbatim: "Discovery is reported within [24 hours]; the prompt, output, account, and any downstream artifacts are preserved, and tool/chat history is not deleted while the incident is open."
- ^a Why: GLBA's Safeguards Rule requires a written incident-response plan, and the FTC notification obligation (and parallel banking breach-notification expectations) can be triggered by unauthorized exposure of customer information — AI is just one more channel that exposure can flow through.
- ^a Recommended: govern exceptions explicitly. Adopt verbatim: "Any exception to this policy requires written AI Program Owner approval, a stated business justification, compensating controls, an expiration date not to exceed [12 months], and entry in the exceptions log reported to the Board committee."
- ^a What good looks like: an exceptions log with expiration dates and compensating controls. Common mistake examiners flag: informal, undocumented exceptions ("we let the loan team use it") with no owner, no end date, and no compensating control.

SECTION 09

Training & policy review cycle

A policy no one is trained on is unenforceable, and a policy that never changes goes stale in a field moving this fast. Train on adoption and annually, and review the policy on a fixed cadence plus event triggers.

- ^a Recommended: mandatory, role-aware training. Adopt verbatim: "All staff complete AI-use training before being granted access to approved AI tools and at least annually thereafter; staff in lending, BSA/AML, and other regulated functions receive role-specific training on permitted uses and prohibitions."
- ^a Why: GLBA's Safeguards Rule expressly requires security-awareness training and qualified personnel; AI-specific training is the natural extension and is a low-cost item examiners notice when it is missing.
- ^a Recommended: fixed review cadence plus triggers. Adopt verbatim: "This policy is reviewed and re-approved at least annually and additionally upon: a new tool listing, new or amended regulatory guidance on AI, a material incident, or a significant change in [Institution]'s AI usage."
- ^a Recommended: version and approve. Adopt verbatim: "Each version records its effective date, approver, and a summary of changes; the current version is published where staff access AI tools."
- ^a What good looks like: a dated, board-approved policy with a training completion record and a change log. Common mistake examiners flag: an undated policy, no evidence of training completion, and a review date that has already lapsed.

SOURCE BASIS

- GLBA Safeguards Rule — 16 CFR Part 314 (FTC); parallel Interagency Guidelines Establishing Information Security Standards for depository institutions
- SR 11-7 — Supervisory Guidance on Model Risk Management (Federal Reserve / OCC Bulletin 2011-12)
- Interagency Guidance on Third-Party Relationships: Risk Management (FRB / FDIC / OCC, June 6, 2023; 88 FR 37920)
- ECOA / Regulation B (12 CFR 1002) and CFPB Circular 2023-03 on adverse-action notices using AI/complex models
- NIST AI Risk Management Framework (AI RMF 1.0, NIST AI 100-1, Jan 2023): Govern, Map, Measure, Manage
- AIEOG AI Lexicon — US Treasury / FBIIC / FSSCC (Feb 19, 2026)

ADAPT BEFORE ADOPTION

This is a starter template, not legal advice or an examiner-approved policy. Replace every [bracketed] placeholder, align the language with your institution's policies, and route the final document through compliance, risk, and legal review.